The integration between Catalog Service and Keycloak is now established. Next you'll define some basic security policies to protect the application endpoints.

DEFINING SECURITY POLICIES FOR JWT AUTHENTICATION

For the Catalog Service application, we want to enforce the following security policies:

- `GET` requests to fetch books should be allowed without authentication.
- All other requests should require authentication.
- The application should be configured as an OAuth2 Resource Server and use JWT authentication.
- The flow for handling JWT authentication should be stateless.

Let's expand on the last policy. Edge Service triggers the user authentication flow and leverages the web session to store data like ID Tokens and Access Tokens that would otherwise get lost at the end of each HTTP request, forcing a user to authenticate at each request. To make it possible for the application to scale, we used Spring Session to store the web session data in Redis and keep the application stateless.

Unlike Edge Service, Catalog Service only needs an Access Token to authenticate a request. Since the token is always provided in each HTTP request to a protected endpoint, Catalog Service doesn't need to store any data between requests. We call this strategy *stateless authentication* or *token-based authentication*. We use JWTs as Access Tokens, so we can also refer to it as *JWT authentication*.